NAVY POČÍTAČOVÁ BEZPEČNOST

Cv3. SQLi a vlastní Fuzzer

Průlom do systému – Získání administrátorského přístupu (SQL Injection)

Cíl cvičení: Pochopit princip zranitelnosti SQL Injection (SQLi) a využít ji k obejití přihlašovacího formuláře. Vaším cílem je přihlásit se jako administrátor e-shopu, aniž byste znali jeho heslo.

Teoretický úvod: Jak funguje přihlašování?

Když do přihlašovacího formuláře zadáte e-mail a heslo, webová aplikace tyto údaje ověří oproti databázi. V základní verzi pak vypadá dotaz takto:

```
SQL
SELECT * FROM Users WHERE email = 'vas  email@test.cz' AND password = 'vase  heslo';
```

Kde je chyba?

Pokud programátor neošetří vstupy od uživatele (tzv. *sanitization*), můžete do pole pro e-mail zadat speciální znaky, které změní samotnou strukturu SQL dotazu. Tomuto útoku se říká **SQL Injection**.

Krok 1: Hledání zranitelného místa

1. V horním menu aplikace (Account / Účet) přejděte na stránku **Login (Přihlášení)**.
2. Zkuste zadat náhodný e-mail (např. `test@test.cz`) a náhodné heslo.
3. Sledujte chování aplikace. Jakou chybovou hlášku vám vrátí?

Krok 2: Testování speciálních znaků

Nejlepším přítelem penetračního testera při hledání SQL injection je **jednoduchý apostrof (')**. Ten v SQL jazyce ohraničuje textové řetězce.

1. Do pole pro e-mail zadejte pouze znak apostrofu: `'`
2. Do pole pro heslo zadejte cokoliv (např. `1234`).
3. Klikněte na Log In. Pokud aplikace zareaguje neočekávaně, našli jste zranitelné místo!

Krok 3: Samotný útok (Exploitation)

Nyní víte, že můžete ovlivnit databázový dotaz. Váš cíl je upravit pole `email` tak, aby byl dotaz vždy pravdivý (TRUE) a zároveň aby databáze ignorovala kontrolu hesla.

V SQL se zbytek řádku zakomentuje pomocí dvou pomlček (`--`).

Zkuste vymyslet, co přesně napsat do pole e-mail, aby se původní dotaz:

`SELECT * FROM Users WHERE email = ' [VÁŠ VSTUP] ' AND password = '...'`

změnil na něco, co dává vždy smysl a ignoruje heslo.

Postupné nápovědy (pokud se zaseknete):

- 💡 **Nápověda 1:** můžete využít princip tautologie.

Úspěšné dokončení

Pokud jste zadali správný "payload", aplikace vás přihlásí. Poznáte to tak, že v horním menu uvidíte e-mail administrátora a zpřístupní se vám nové funkce.

Zároveň, pokud se podíváte na svůj **Scoreboard**, uvidíte, že jste splnili úkol "Login Admin".

Krok 4: Bonusový úkol - Automatizace útoku (Tvorba fuzzeru)

Zkuste si ruční testování zautomatizovat. Vaším úkolem je napsat jednoduchý skript v Pythonu, který bude fungovat jako fuzzer. Stáhněte si profesionální slovník SQLi payloadů z repozitáře SecLists a naprogramujte testovací smyčku. Ta bude jednotlivé payloady ze slovníku automaticky odesílat pomocí požadavků `POST` přímo na přihlašovací API Juice Shopu. Váš skript by měl vyhodnocovat odpovědi serveru a zastavit se ve chvíli, kdy objeví payload, který úspěšně obejde přihlášení (např. vrátí HTTP status 200).

Krok 5: Bonusový úkol 2 – SQLmap

SQLmap je naprostý průmyslový standard. Je to open-source nástroj spouštěný z příkazové řádky, který dokáže celý proces detekce a zneužití plně zautomatizovat. Zájemci mohou doma vyzkoušet.

https://github.com/sqlmapproject/sqlmap